

Static Analysis Triage Procedure

Revision

Version 2
4/27/26 6:57 PM

SME

Charles Wilson

Abstract

This document describes the procedure used to perform the **triage** activity described in the **AVCDL** ^[1] secondary document **Static Analysis Report** ^[2].

Group / Owner

Security / Security Architect

Motivation

This document is motivated by the need to have early cybersecurity-related implementation feedback in the development of software for use within safety-critical, cyber-physical systems.

Note: Within the context of this document, the terms **security** and **cybersecurity** are used interchangeably. It is presumed that the term **security** is being used in reference to **cybersecurity** and not **physical security**.

License

This work was created by **Torc Robotics** and is licensed under the **Creative Commons Attribution-Share Alike (CC BY-SA-4.0)** License.

<https://creativecommons.org/licenses/by/4.0/legalcode>

Audience

The audience of this document is the cybersecurity practitioner who will be conducting cybersecurity-specific static analysis.

Completeness of Output

Since static analysis is an as-is analysis, it is critical to ensure that the information gathered is as accurate and complete as possible. As with any cybersecurity assessment, it is not the place of the cybersecurity SME to make assumptions on the part of engineering. All information should be sourced from and confirmed by the owner of the element under consideration.

Disposition of Output

Once completed, the generated output (**Static Analysis Report**) should be managed in the organization's document management system (DMS) as a document of record.

Entry Criteria

This document assumes that the reader understands the purpose of cybersecurity-specific static analysis. Further, that the reader has read and understood the AVCDL **Static Analysis Report** [\[2\]](#) secondary document.

Prerequisites – Development SME

Qualifications

It is required that the development SME is both a qualified and trained development SME with expertise in the element under consideration.

Note: The specific qualifications and training of development SMEs necessary to assert expertise in providing accurate information regarding the element under consideration is outside the scope of this document.

Note: The development group is responsible for determining and making available the appropriate SME for the analysis of the element under consideration.

Knowledge

It is required that the development SME have expertise in the element under consideration in the context of the tool which generated the cybersecurity issues under review.

Prerequisites – Security SME

Qualifications

It is required that the security SME is both a qualified and trained security architect (shown above on title page as **Owner**) as defined by the **NIST NCWF** role SP-ARC-002 and detailed in the **NCWF Roles - Security Architect** section of the **AVCDL Background Material** elaboration document [\[6\]](#).

Knowledge

It is required that the cybersecurity SME understands the purpose of cybersecurity-specific static analysis.

Background Information

It is required that the cybersecurity SME has read and understands the AVCDL **Static Analysis Report** secondary document. Additionally, that the cybersecurity SME has taken training relevant to this activity.

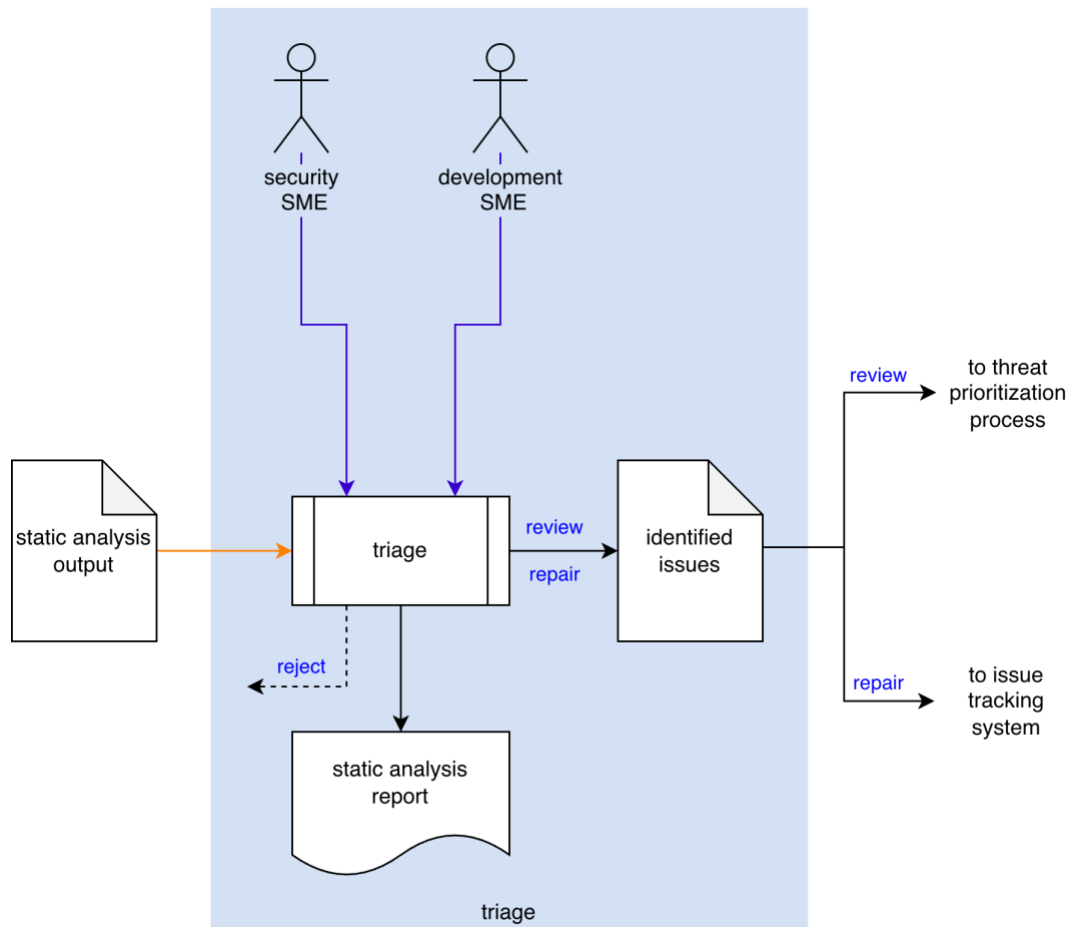
Prerequisites – Input Materials

It is required that the cybersecurity SME acquire all relevant documentation related to the tool under consideration necessary to complete the procedure.

It is required that the development group provide all relevant documentation related to the element under consideration necessary to complete the procedure.

Triage Activity

The workflow diagram for the **triage** activity of the **Static Analysis** process is shown below.



The **Security SME** and the **Development SME** review the **Static Analysis Output** to identify any anomalous behavior needing further investigation. **Identified Issues** are sent to the threat prioritization process [\[5\]](#). A **Static Analysis Report** will be generated.

Note: Depending on the nature of an identified issue, it may be entered directly into the issue tracking system.

Note: The recommended form of the **Identified Issues** artifact is JSON-encoded Static Analysis Results Interchange Format (**SARIF**). This document assumes SARIF version 2.1.0 [\[4\]](#) or later.

Methodology

The purpose of triage is first and foremost to eliminate those issues which are false positives. A secondary goal is to identify “must fix” issues. What remains is put into the threat prioritization process.

There are three options when dispositioning an issue. These are:

Reject

This disposition should be assigned when the issue is determined to be a false positive. The Security SME should review the option generating the issue. If it is determined that the option is not released, it should be removed. If the issue is merely contextually incorrect, the code should be annotated to disable scanning for the identified region. The analysis should be re-run to verify that the issue is no longer flagged.

Review

This disposition should be assigned when the issue is determined to be valid but requires additional review via the threat prioritization process.

Repair

This disposition should be assigned when the issue is clearly one which requires mitigation. These issues should be directly entered into the issue tracking system.

Implementation

Given that there are two distinct approaches to implementing cybersecurity-relevant static analysis, there are two corresponding means of documenting the triage activity.

Static Analysis Tools

It is typical for a standalone static analysis tool to provide a mechanism for performing the triage activity. They also provide report generation.

Note: These tools also typically have the capability of exporting their results in the form of SARIF files. When this is the case, they may be treated in the same manner as non-static analysis tools.

Tools with Static Analysis-like Features

Tools which are not purpose-built for static analysis, but provide static analysis-like information, such as compilers and linters may have support for SARIF output. When this is the case, the approach for triage laid out in the following section may be used. When the tool does not provide SARIF output, an additional step may be required in order to provide each cybersecurity relevant issue with a unique ID in order to differentiate between them.

Note: It is recommended that when using non-static analysis tools for cybersecurity-specific static analysis within the build system that they be run separately with only cybersecurity-relevant settings in order to minimize the work required to perform the triage.

Note: There may be the desire to enable cybersecurity-relevant settings for non-static analysis tools directly in order to provide direct developer feedback. This should be avoided until the scale of the issues is understood.

Static Analysis Triage Template

The triage activity may be documented using the **AVCDL static analysis triage template** Microsoft Excel workbook [\[4\]](#).

Note: Other forms of documentation are permissible so long as they provide the information laid out in this document.

There are five sheets in the workbook. They are:

- [Cover sheet](#)
- [Revision history](#)
- [Reference documents](#)
- [Triage determination](#)
- [Legend](#)

These will be addressed in turn.

Duplication of Rows in the Various Sheets

When there is the need to add rows to the various sheets of the workbook, be sure to duplicate an existing row. This is because validation checks are attached to some of the cells which also enables the use of dropdown lists.

Cover Sheet

The **cover sheet** of the workbook is shown below:

Static Analysis - Triage							
Element Name	Element Name						
Element Scope	Element Scope						
Vendor Name	Vendor Name						
Security SME	Security SME						
Development SME	Development SME						
Date	27-Aug-2000						
Model Revision	1						

Fields to be completed are shown in **red**.

Element Name

The **element name** is the element whose static analysis issues are being triaged.

Element Scope

The scope of the element is left to the discretion of the customer. Examples of element scopes include system, sub-system, component, component software (non-OS), and component OS.

Note: In this context, **the customer** refers to the entity requiring the activity.

Vendor Name

This is the name of the vendor responsible for the element under consideration.

Security SME

This is the static analysis subject matter expert triaging the static analysis output.

Development SME

This is the development subject matter expert providing information about the element.

Date

This is the date when the element's static analysis triage was created or updated. The date should be updated whenever the document is updated.

Revision

This is the revision number of the document. The revision number is a monotonic and increasing integer, starting at 1. It should be incremented every time the document is updated.

Revision History

The **revision history** sheet of the workbook is shown below:

Revision History		
Revision	Author	Description
1		initial revision

Revision

The **revision** corresponds to that listed on the cover sheet.

Author

The **author** corresponds to the security SME listed on the cover sheet.

Description

This is a brief description of changes made to the static analysis triage since it was last updated.

Reference Documents

Note: These references are those necessary for the creation of the element's **static analysis output** triage.

Note: Reference to the element's static analysis output should be included.

The **references** sheet of the workbook is shown below:

Reference Documents		
Name	Description	Location

Name

This is the name of the document being referenced.

Description

This is a brief description of the document being referenced.

Location

This is the location of the document being referenced. It may be a physical location or a URL.

Triage Determination

The **triage determination** sheet of the workbook is shown below:

Triage Determination				
issue ID	determination	preliminary severity	justification	notes

Issue ID

This is the unique element static analysis issue ID.

Determination

This is the determination of the issue's triage. It may be one of the following:

- reject
- review
- repair

Note: The meanings of these were covered earlier in this document.

Preliminary Severity (optional)

If the determination is that the issue is valid, a **preliminary severity** (rank / likelihood) may be provided.

Note: The **preliminary severity** value set is not provided as it is highly specific to the organizational and domain. A discussion of quantized rank values can be found in the **Ranked / Risked Threat Report** ^[10] ACVDL secondary document.

Justification

This is the justification for the selected determination.

Note: If the determination is that the issue is **reject**, a justification is required.

Notes

This is a general notes field.

Legend

The **legend** sheet of the workbook is shown below:

determination
reject
review
repair

The **legend** sheet information is used to make the completion of the document easier by providing dropdown lists for common values. It also ensures that spelling errors do not creep into the generated material.

Note: The legend sheet should not be edited. If an unlisted value is required, the template should be separately revised.

Static Analysis Report

The **Static Analysis Report** is the human-readable record of the activity. It is intended to be a standalone document for audit purposes. It's preferred embodiment for storage in the DMS is PDF. The content of the report is covered in the **Static Analysis Report** AVCDL secondary document.

Note: If possible, it is recommended that the static analysis report be generated programmatically. Creating the report from the JSON-encoded SARIF for the **Identified Issues** file makes this process much easier.

Note: Although all issues contained in the **Static Analysis Output** may be included in the report, it is recommended to restrict the report to only those items which are not rejected. Additionally, it is recommended that the items chosen for **review** and **repair** be in separate sections.

Exit Criteria

This procedure is considered complete once the **Static Analysis Report** has been entered into the organization's DMS as a document of record.

Note: The processes and procedures for entering documents into the DMS, or the updating thereof, are outside the scope of this document.

References

1. **AVCDL** (AVCDL primary document)
2. **Static Analysis Report** (AVCDL secondary document)
3. **Static Analysis Perform Analysis Procedure** (AVCDL tertiary document)
4. **Static Analysis Results Interchange Format (SARIF) Version 2.1.0**
<https://docs.oasis-open.org/sarif/sarif/v2.1.0/os/sarif-v2.1.0-os.pdf>
5. **Threat Prioritization Plan** (AVCDL secondary document)
6. **AVCDL Background Material** (AVCDL elaboration document)